

AETHERIA INFRASTRUCTURE RESEARCH (AIR)

ISMS Portfolio — Executive Summary

ISO/IEC 27001:2022 | April – May 2026

Project Overview

Aetheria Infrastructure Research (AIR) is a European research organization with headquarters in Madrid specialising in critical infrastructure analysis and AI-powered resilience modelling. With 145 staff across offices in Madrid, Brussels, and Riga, AIR conducts government-commissioned research programmes, operates the ARIA AI platform, and consults infrastructure operators and national authorities across Europe.

In early 2026, AIR initiated a formal plan to design, document, and implement an Information Security Management System (ISMS) aligned to ISO/IEC 27001:2022, with a target of achieving certification by Q1 2027. The reason was twofold: ISO 27001 certification is becoming a standard requirement in government research procurement, and a 2024 near-miss event involving a stale contractor account made clear that AIR's security posture needed to be formalised and managed.

Twelve documents were produced across two months, covering every mandatory element of ISO/IEC 27001:2022, from organisational context and risk assessment to policy development, a simulated internal audit, and a security improvement roadmap.

Portfolio Documents

The twelve documents reflect the natural lifecycle of an ISMS, beginning with the organisational context that determines what needs to be protected, moving through risk identification and policy development, and concluding with audit and improvement planning.

AIR-ISMS-ORG-001 <i>Organisation Profile</i>	Establishes AIR's internal and external context per ISO 27001:2022 Clause 4.1 and 4.2. Documents governance structure, strategic objectives, regulatory obligations, and the threat landscape.
AIR-ISMS-SCO-001 <i>ISMS Scope Statement</i>	Defines the ISMS boundary: what is included (all three locations, 145 personnel, 12 systems) and what is excluded (personal devices, home networks, client-operated systems), with documented justifications for each exclusion.
AIR-ISMS-AST-001 <i>Information Asset Inventory</i>	Catalogues 11 primary information assets and 12 supporting technical assets. Each asset is classified (Restricted to Public), assigned an owner, and linked to applicable risks.
AIR-ISMS-RSK-001 <i>Risk Assessment Methodology</i>	Defines AIR's risk scoring framework: a 5×5 likelihood and impact matrix, risk appetite, and the treatment options available to asset owners.
AIR-ISMS-RSK-002 <i>Risk Register</i>	Documents 13 identified risks across identity, data, AI, infrastructure, and legal domains. Risks range from High to Low. Each risk has an owner, treatment status, and residual score.
AIR-ISMS-POL-001 <i>Information Security Policy</i>	The top-level management mandate. Includes a CEO statement of commitment, five measurable security objectives, the information classification scheme, and the policy hierarchy.
AIR-ISMS-POL-002 <i>Access Control Policy</i>	Governs the full access lifecycle (provisioning, modification, and deprovisioning) with specific timeframes (accounts disabled within 2 hours of departure), MFA requirements, privileged access management, and a contractor access framework.
AIR-ISMS-POL-003 <i>Incident Response Policy</i>	Defines AIR's P1–P4 severity classification, response lifecycle, mandatory response timeframes, GDPR 72-hour notification obligations, government partner notification requirements, and evidence handling procedures.

AIR-ISMS-EXR-001 <i>IR Tabletop Exercise (Operation Stale Key)</i>	A fully scripted tabletop scenario in which a stale contractor account is exploited to access 4.1 GB of Restricted research data. Tests detection, classification, containment, legal obligations, and media handling, with notes and a debrief.
AIR-ISMS-SOA-001 <i>Statement of Applicability</i>	Assesses all 93 ISO/IEC 27001:2022 Annex A controls for applicability and implementation status. All 93 controls are applicable. 9 are fully implemented, 63 are partially implemented, and 21 are not yet implemented, each with documented evidence references and responsible owners.
AIR-ISMS-AUD-001 <i>Internal Audit Report and Findings Log</i>	A simulated first internal audit producing 12 findings: 2 major non-conformities (supplier security and GDPR record-keeping), 5 minor non-conformities, 5 observations, and 8 conformities.
AIR-ISMS-RMP-001 <i>Security Improvement Roadmap</i>	A 10-month Gantt chart roadmap of 48 initiatives across 9 workstreams. Includes a pre-certification checklist tracking every condition AIR must satisfy before submitting for external audit.

Key Findings

The risk assessment and internal audit produced a consistent picture of AIR's security posture: the foundations are sound, but several operational controls are either absent or not consistently applied. The most significant findings are described below.

The Risk Register identified 13 risks, of which 10 were rated High. No Critical risks were identified. The High-rated risks group around three themes: identity and access management (overprivileged contractor accounts, weak MFA coverage, incomplete offboarding), data protection (shadow AI tools processing Restricted data, insider IP exfiltration), and infrastructure resilience (inadequate backup, logging gaps).

The internal audit produced two major non-conformities. The first was the complete absence of a supplier security assessment process: suppliers with access to Restricted government research data had never been subject to a security review, and two of three contracts contained no information security requirements whatsoever. The second was an incomplete GDPR Record of Processing Activities. A draft started in 2024 had never been completed, leaving AIR in active non-compliance with GDPR Article 30 and without Data Protection Impact Assessments for its most sensitive processing activities.

Five minor non-conformities were identified: five accounts using SMS-based MFA in breach of the Access Control Policy; one contractor account found to be still active 11 days after the contractor's departure, consistent with the risk register finding on incomplete offboarding; no completed annual employee access review despite the policy requiring one; 40% of sampled staff having no security training record; and three log sources not forwarding data to the central Log Analytics Workspace, with two sources below the policy-mandated 90-day retention minimum.

Eight areas of genuine conformity were noted, including: a comprehensive and well-maintained asset inventory; clear evidence of executive leadership commitment; a well-structured incident response policy with a tabletop exercise planned; NDA and employment security obligations in place across the workforce; Microsoft Defender for Endpoint deployed across 100% of managed devices; and Privileged Identity Management correctly configured with just-in-time activation for all global administrator roles.

The overall audit conclusion was that AIR's ISMS is at an early but credible stage of development. The two major non-conformities are addressable within 60–90 days. Provided these are closed and the minor non-conformities are on a documented treatment plan, AIR would be in a reasonable position to proceed with an external Stage 1 certification audit in Q4 2026.

Certification Pathway

The Security Improvement Roadmap (AIR-ISMS-RMP-001) translates the audit findings, risk register treatment actions, and Statement of Applicability gaps into 48 concrete initiatives, planned across a 10 month period from June 2026 to March 2027.

The immediate priority, Q2 and Q3 2026, is to close the two major non-conformities and the five minor non-conformities. This means completing the ROPA and initial DPIAs, deploying the supplier security questionnaire, migrating all accounts from SMS to Authenticator MFA, resolving the stale contractor account and implementing automated deprovisioning, completing the first annual employee access review, delivering security training to all staff without a training record, and connecting the missing log sources with appropriate retention periods.

The Q4 2026 phase focuses on pre-certification readiness: a follow-up internal audit to verify NCR closure, completion of all six policies, a formal management review per ISO 27001:2022 Clause 9.3, an external penetration test, and submission of the Stage 1 external audit application. The Stage 1 documentation review is planned for December 2026, with the Stage 2 on-site certification audit targeted for March 2027.

A pre-certification checklist is embedded in the roadmap, covering every condition AIR must satisfy before the Stage 1 application is submitted.

Conclusion

This portfolio demonstrates what a complete, coherent ISMS looks like in practice for a mid-sized European research organisation operating in a sector of high sensitivity. Every document is based on AIR's specific technology environment, workforce, regulatory obligations, and threat landscape. The risk register informs the policies; the policies are tested in the tabletop exercise; the Statement of Applicability maps every control; the audit verifies the controls against evidence; and the roadmap turns the findings into an improvement programme.

The portfolio was designed to reflect realistic organisational, operational, and regulatory challenges commonly faced by research organisations operating in high-sensitivity environments. The objective was to develop a practical ISMS framework grounded in risk management, governance, and continuous improvement principles aligned with ISO/IEC 27001:2022.

Full project documentation available at: github.com/SantaLauk/ISMS-Portfolio-AIR